MOTOSECURE | A NEXUS TECH LABS PRODUCT

Security, Privacy and Governance Policy

Proposed operating policy for a pilot deployment with municipal authorities

Document ID	MS-SEC-001
Version	1.0 (draft for review)
Date	2 November 2026
Status	Draft for institutional review
Classification	Confidential
Publisher	NEXUS Tech Labs
Baseline	MotoSecure source archive as reviewed on 2 November 2026 (backend, web, mobile)
Related documents	MS-ARCH-001 Architecture; MS-SRS-001 Requirements; MS-ASR-001 Security Assessment Report
Nature of document	Proposed policy for adoption. Not legal advice. Items marked 'validate' need confirmation by qualified counsel and the pilot partner.
Approval	[Name, title and date - to be completed by the document owner]

This document describes the software as implemented in the reviewed source archive. Statements about hosting and deployment reflect the owner's reported configuration and were not independently verified. It is not a security certification, penetration-test report or compliance assessment.

Contents

1. Purpose, scope and status 3
2. Roles and responsibilities 3
3. Data inventory and classification 3
4. Access management 4
4.1 Principles 4
4.2 Account lifecycle 4
4.3 Authentication standards 5
4.4 Privileged and infrastructure access 5
5. Data handling rules 5
6. Retention and disposal 6
7. Cryptography and secrets management 6
8. Audit logging and monitoring 7
8.1 What is recorded 7
8.2 What is not recorded 7
8.3 Protection and review 7
9. Secure development and change management 7
10. Backup, continuity and recovery 7
11. Incident response 8
11.1 Severity levels 8
11.2 Process 8
11.3 Specific playbooks 8
12. Third-party processors and hosting 9
13. Transparency and individual rights 9
14. Legal, regulatory and institutional points requiring validation 9
15. Policy governance 10
Appendix A. Pre-pilot checklist 10

1. Purpose, scope and status

This policy sets out how MotoSecure should be operated so that rider, vehicle and enforcement data are protected and so that the people responsible for the system can be held to account. It covers the software, its hosting and the people who administer or use it.

> **Status of this document**
> This is a **proposed** policy prepared from the implemented software. It has not been adopted by any institution, and nothing in it has been reviewed by a lawyer. Where it states what the software does, that is taken from the source code; where it states what an organisation must do (procedures, reviews, contacts), those are proposals the pilot partner must accept, adapt and assign to named people. Legal and institutional points are collected in section 14 and are flagged **validate** where they appear.

Each control is labelled **[Software]** (built into MotoSecure today), **[Software gap]** (not built; the procedure must compensate) or **[Procedure]** (an organisational action).

2. Roles and responsibilities

Role	Held by	Responsibilities
Data controller	Each municipality for its own data (validate; the Ministry may be a joint controller for national use)	Decides purposes and retention; approves who may access data; answers data-subject requests; accepts the residual risks in the Security Assessment Report
Operator / processor	NEXUS Tech Labs (validate the exact legal role and contract)	Runs and maintains the platform; applies this policy's technical controls; reports incidents to controllers; does not use municipal data for other purposes
Municipal data and security lead	To be designated by each municipality	Approves accounts, reviews access and audit logs, first contact for incidents
Platform administrator (super_admin)	Named NEXUS staff only	Creates municipalities and accounts; holds the highest privilege; every action is attributable to a named person
Mayor and council staff	Municipal employees	Approve syndicates and riders; use data only for transport regulation and enforcement
Syndicate administrators	Union officers	Keep their members' data accurate; enrol only genuine members; protect their credentials
Enforcement officers	Municipal enforcement staff	Use the app only for lawful checks; protect the phone and sign-in; report loss immediately
Hosting and service providers	Render, MongoDB Atlas, Google (email), Expo (reported)	Provide infrastructure under their own terms; see section 12

3. Data inventory and classification

Classification levels: **Restricted** (identity numbers, credentials), **Confidential** (personal and operational data), **Internal** (non-personal operational data), **Public** (information intended for the public).

Data	Examples	Class	Where it is held	Who can see it in the system
Account data	Name, email, phone, role; password hash (never shown)	Confidential; hash Restricted	Database	Own record only (no screen or API lists user accounts)

Data	Examples	Class	Where it is held	Who can see it in the system
Rider identity	Full name, phone, licence number and expiry, photo URL	Confidential	Database	Council, own syndicate; officers see name and licence expiry, not phone
Rider identity numbers	National ID number, date of birth	Restricted	Database (excluded from queries by default)	Council and own syndicate in the single-rider detail view only
Vehicle data	Plate, chassis number, insurance and technical-control dates	Confidential	Database	Council, own syndicate; officers see plate
Enforcement records	Scan and incident history, officer, severity, free-text description, location label	Confidential	Database; recent scans on officer phones	Council; syndicate administrator for own riders
Audit records	Actor, role, action, target, IP address, time	Confidential	Database	Council roles for their municipality
Offline snapshot	Badge id, name, status, licence expiry, syndicate and plate for a municipality	Confidential	Officer's phone storage (not encrypted)	Anyone with access to the unlocked phone
Session tokens	JWT	Restricted	Browser localStorage / phone storage	Holder of the device
Public information	List of municipalities open to enrollment	Public	Database	Anyone

Data that MotoSecure does **not** currently collect: photographs (a URL field exists, no upload), biometrics, precise GPS tracks, payment data, rider health information. Adding any of these requires a new privacy assessment.

4. Access management

4.1 Principles

- **Least privilege and tenant isolation.** [Software] Each role sees only what its function requires, and a user of one municipality can never read or change another's data; a syndicate administrator sees only their own syndicate. Rules are in the SRS, section 3.
- **Named accounts.** [Procedure] Every user has a personal account. Shared logins are prohibited. Demonstration accounts must not exist in any pilot or production database.
- **Separation of duties.** [Software] A syndicate cannot approve itself and cannot change a rider's status; only council roles can, and each change is recorded.

4.2 Account lifecycle

Stage	Required action	Tooling today
Joiner	Written request from the municipal lead; role and scope (municipality, syndicate) recorded; account created with a one-time password that the user must replace	[Software gap] No screen or API creates staff or officer accounts; the operator uses a database script
Mover	Role or scope change approved by the municipal lead; old access removed	[Software gap] No role-change tooling

Stage	Required action	Tooling today
Leaver	Account deactivated the same day the person leaves or loses their phone	[Software] Setting isActive to false takes effect immediately on the next request (tokens are re-checked on every call); [Software gap] no screen to do it
Review	Municipal lead reviews the list of accounts and roles every quarter and signs it off	[Procedure]

4.3 Authentication standards

- [Software] Passwords: at least 8 characters with a letter and a digit, at most 72 bytes; hashed with bcrypt. Five consecutive failures lock an account for 15 minutes. Reset links expire after one hour, work once, and end all earlier sessions.
- [Procedure] Recommended minimum for privileged roles (super_admin, mayor, municipal_staff): passphrases of at least 12 characters, not reused elsewhere, kept in a password manager.
- [Software gap] Multi-factor authentication is not available. Until it is, privileged accounts must be limited in number and reviewed monthly.
- [Software gap] Sessions last up to 7 days and cannot be revoked individually; deactivating the account or resetting the password ends them.

4.4 Privileged and infrastructure access

- [Procedure] Access to the Render, MongoDB Atlas, GitHub, Expo and email accounts is restricted to named administrators, each with two-factor authentication enabled on their provider account, and reviewed quarterly.
- [Procedure] Direct database access is exceptional, ticketed and logged; routine work uses the application.
- [Procedure] Break-glass: one documented emergency procedure for the platform administrator, with the use reported to the municipal lead within 24 hours.

5. Data handling rules

- **Purpose limitation.** Data is used only for registering and regulating motorcycle-taxi operations and for lawful enforcement. Any other use, including disclosure to third parties, requires the controller's written approval (validate for requests from police or courts).
- **Minimisation.** [Software] Anonymous callers and officers from other municipalities receive only a verdict and masked name; officers never receive phone numbers or identity numbers; lists never include identity numbers.
- **Field use.** [Procedure] Officers use only the official app, keep the phone locked with a screen lock, install no untrusted software, do not photograph or forward rider details, and report a lost or stolen phone at once so the account can be deactivated.
- **Offline data.** [Software] The snapshot excludes contact and identity numbers and is deleted on sign-out. [Software gap] It is not encrypted on the device; this is an accepted risk for the pilot until device encryption is added.
- **Badges.** [Procedure] Badges are printed only from the dashboard by authorised staff and handed over in person after identity check. A lost badge is replaced by revoking the rider's status and reissuing; the badge id cannot be reused.
- **Test and demonstration data.** [Procedure] Real personal data must never be used in development or demonstrations. Demo data is generated by the seed script, which refuses to run without an explicit wipe confirmation and must never be pointed at a database containing real data.

- **Exports.** [Software gap] There is no export function. Any extract taken from the database must be approved by the controller and stored encrypted.

6. Retention and disposal

> **Validate**
> The software does not delete or anonymise anything automatically and has no deletion routes. The periods below are **proposals** for the controller to decide and for counsel to check against public-records and data-protection rules.

Record	Proposed retention	Mechanism today
Active rider, bike, syndicate and account records	For as long as the person or syndicate is enrolled	Manual database operation
Revoked or ended rider records	24 months after revocation, then anonymise or delete	[Software gap] No tool
Enforcement log (verifications)	24 months	[Software gap] No tool
Incident records	Longer of 5 years or the period needed for any proceedings	[Software gap] No tool
Audit log	At least 5 years	Kept indefinitely; append-only through the application
Password-reset tokens	One hour	[Software] Expire automatically
Offline snapshot and queue on phones	Until sign-out or next refresh	[Software] Removed on sign-out
Backups	35 days rolling	[Software gap] Not configured in the repository

7. Cryptography and secrets management

- **In transit:** [Procedure] The API and web app must be served only over HTTPS; the application relies on the hosting platform for TLS and does not itself enforce it.
- **At rest:** [Procedure] Confirm that the database tier in use encrypts data at rest and that backups are encrypted; the repository cannot show this. **Validate** with the provider.
- **Passwords and tokens:** [Software] bcrypt for passwords, SHA-256 for reset tokens, HS256-signed session tokens.
- **Secrets:** [Software] No secret is committed; configuration is by environment variable, and the API refuses to start with a missing or weak signing secret. [Procedure] Secrets live only in the hosting dashboards or a password manager, never in chat, email, tickets or archives. Any secret that has been shared in clear text must be rotated before the pilot.
- **Rotation:** [Procedure] Rotate the signing secret, database password and email app password at least every 12 months, immediately after any suspected exposure, and when a person with access leaves. Rotating the signing secret signs every user out.

8. Audit logging and monitoring

8.1 What is recorded

[Software] Syndicate registered, created, updated, approved, rejected, suspended; rider created, updated, status changed; bike created, updated; municipality created, updated; account locked; password reset completed. Each entry names the actor and role, the target, previous and new values where relevant, the IP address and the time. Passwords and tokens are never recorded. Verification scans and incidents are recorded in the enforcement log.

8.2 What is not recorded

- [Software gap] Successful sign-ins, failed sign-ins (other than lockouts) and read access to records are not logged.
- [Software gap] There is no central log store, alerting or anomaly detection; request logs exist only in the hosting provider's console.

8.3 Protection and review

- [Software] The audit log cannot be altered through the application. [Software gap] Someone with database credentials can alter it; for the pilot, database credentials must be limited to named administrators, and a database role without update or delete rights on the audit collection should be introduced.
- [Procedure] The municipal lead reviews the audit log monthly for unexpected approvals, status changes and lockouts and records that the review took place.

9. Secure development and change management

- [Procedure] No change is deployed until the automated tests pass (npm test in the backend), the static check reports no high findings (npm run check:static), and dependency advisories have been reviewed (npm run audit:deps in backend, web and mobile).
- [Procedure] Changes go through code review by a second person where available, and are deployed first to a staging environment with its own database. At present no staging environment is defined.
- [Procedure] Dependencies are reviewed monthly and security updates applied promptly; the lock files are committed.
- [Procedure] Production data is never copied to development. Production secrets are never reused in other environments.
- [Procedure] A security contact address for reporting vulnerabilities is published by the operator [to be assigned]; reports are acknowledged within 3 working days.

10. Backup, continuity and recovery

- [Software gap] No backup or restore procedure exists in the repository. Before the pilot, enable automated database backups with encryption, set a recovery point and recovery time objective with the municipality, and test a restore at least quarterly.
- [Software] Offline scanning provides partial continuity for officers if the service or network is unavailable; results are indicative and carry the snapshot date.
- [Procedure] If the service is unavailable, officers revert to the existing manual procedure; the municipality decides how scans made manually are reconciled afterwards.
- [Procedure] Free or entry-level hosting tiers sleep when idle and have no availability commitment; a pilot with real enforcement reliance should use a tier with defined availability.

11. Incident response

11.1 Severity levels

Level	Definition	Examples	Initial response
1 - Critical	Confirmed exposure or alteration of personal data, or loss of control of a privileged account or secret	Database credentials leaked; mayor account taken over; data copied out	Immediately contain (rotate secrets, deactivate accounts), inform the municipal lead and operator lead within 1 hour
2 - High	Likely exposure or serious misuse, or outage of enforcement function	Officer phone lost with active session; repeated lockouts on a privileged account; API down during operations	Deactivate affected accounts, investigate within 4 hours
3 - Medium	Policy breach without evidence of exposure	Shared login discovered; demo account found in production	Correct within 2 working days
4 - Low	Suspicious but unconfirmed, or minor	Unexplained failed logins on one account	Review within 5 working days

11.2 Process

1. **Detect and report.** Anyone who suspects an incident reports it to the municipal lead and the operator's security contact [to be assigned]. Sources: users, audit-log review, hosting alerts, provider notices.
2. **Triage.** Assign a severity, an incident owner and a log of actions and times.
3. **Contain.** Deactivate affected accounts (immediate effect), rotate exposed secrets, block abusive sources at the hosting layer, preserve logs and evidence.
4. **Eradicate and recover.** Fix the cause, restore from a clean backup if data was altered, and confirm normal operation.
5. **Notify.** The controller decides on notification to the data-protection authority, affected individuals and ministries. **Validate** the deadlines and thresholds that apply under Cameroonian law; do not assume periods taken from other jurisdictions.
6. **Review.** Within 10 working days write a short post-incident review: cause, impact, what worked, corrective actions with owners and dates.

11.3 Specific playbooks

Situation	Actions
Officer phone lost or stolen	Deactivate the officer's account (the next request from the phone is refused); the locally cached snapshot remains on the phone but contains no phone numbers or identity numbers; issue a new account; record the incident
Credential or secret exposed (for example posted in chat or committed)	Treat as compromised: rotate the secret, review recent audit and database activity, and, for the signing secret, expect all users to sign in again
Suspected takeover of a council account	Deactivate it, reset the password, review audit entries for that actor, and check for approvals or status changes that must be reversed
Wrongly revoked or wrongly valid badge	Council corrects the rider's status (audited); the next online scan reflects it; offline devices refresh at next connection

12. Third-party processors and hosting

Provider (reported)	Data processed	Matters to confirm (validate)
Render	All API traffic, configuration, application logs	Hosting region; data-processing terms; log retention; availability commitment of the tier in use
MongoDB Atlas	All stored data and backups	Cluster region; encryption at rest; backup features of the tier; access controls and IP allow-list
Google (Gmail SMTP)	Recipient addresses and reset links	Suitability of a personal Gmail account for a government system; move to a dedicated transactional email service under the operator's control
Expo (EAS Build)	Source code and build settings	Account ownership and access control; no production data involved
Google Fonts	Visitor IP address when the web app loads	Self-host the fonts to avoid sending visitor data to a third party

[Procedure] Before the pilot the operator provides the municipality with the written terms under which each provider processes data, and the municipality confirms that the hosting locations are acceptable (section 14).

13. Transparency and individual rights

- [Procedure] Riders must be told, at enrollment, who holds their data, why, who can see it, how long it is kept and how to ask for access or correction. A privacy notice in French and English is needed; none exists today.
- [Procedure] The controller names a contact for requests. The operator supports the controller in finding and correcting a person's records.
- [Software gap] There is no self-service access, correction or deletion function. Correction of riders' details is possible through the existing edit functions; deletion and anonymisation require operator action on the database.
- [Procedure] A syndicate administrator who enrols a rider confirms that the rider has been informed and has agreed to the enrollment where the law requires it (validate the legal basis, since enrollment may be mandatory under municipal regulation).

14. Legal, regulatory and institutional points requiring validation

The following were identified while preparing this policy. They are listed so that counsel and the pilot partner can confirm them; this document does not decide them.

#	Point	Why it matters	Suggested owner
L1	Applicability of Law No. 2024/017 of 23 December 2024 on personal data protection, and the roles of controller and processor. Public sources indicate a transition period to around June 2026 and an implementing decree and supervisory authority whose operational status should be confirmed	Determines registration or authorisation with the authority, required notices, rights procedures and penalties	Counsel for NEXUS and the municipality

#	Point	Why it matters	Suggested owner
L2	Whether processing needs prior declaration or authorisation, and what the authority expects for public-sector processing of identity numbers	May be a precondition for going live	Counsel
L3	Obligations under the 2010 cybersecurity and electronic-communications laws (for example logging, incident reporting, hosting providers)	Possible additional duties for the operator or hosts	Counsel; national cybersecurity body
L4	Location of hosting and any cross-border transfer of data (providers are reported to be hosted outside Cameroon; regions not confirmed)	Data-localisation or transfer conditions may apply to public-sector data	Counsel; Ministry
L5	Legal basis for requiring riders to hold and show a badge, and for officers to scan it (municipal order or national regulation)	Without it, enforcement based on the system may be challenged	Municipality; Ministry of Transport
L6	Treatment of national ID numbers, and rules if riders under 18 are enrolled	Identity numbers and minors' data often carry stricter rules	Counsel
L7	Who bears responsibility for an incorrect verdict (for example a wrongly flagged rider), and the appeal route	Governance and liability	Municipality
L8	Disclosure to police, courts or other agencies, and inter-agency sharing between municipalities and the ministry	Defines lawful disclosure and the audit expected	Municipality; Ministry
L9	Public-records and archiving rules for retention periods in section 6	Retention proposals may conflict with mandatory periods	Municipality; counsel
L10	Public procurement, official-language (French and English) and accessibility requirements for a government system	Contractual and usability conformity	Municipality; Ministry
L11	Whether certification or an independent security audit is required before connection to government systems	Affects timeline	Ministry; national cybersecurity body

15. Policy governance

- **Ownership:** the document owner named on the cover approves this policy and any exceptions. [Procedure]
- **Review:** at least annually, after any severity 1 or 2 incident, and when the software changes in ways that affect data or access.
- **Exceptions:** requested in writing with the risk, compensating measures and an end date; approved by the controller's lead and recorded.
- **Compliance:** breaches of this policy by staff are handled under the employer's disciplinary rules; breaches by providers under their contracts.

Appendix A. Pre-pilot checklist

Item	Owner	Done
Rotate all credentials that have been shared in clear text (database, signing secret, email app password); store only in provider dashboards	Operator	[ ]
Remove demonstration accounts and data from any pilot or production database; create separate development, staging and production databases	Operator	[ ]
Confirm HTTPS only, hosting regions, encryption at rest and backups; test a restore	Operator	[ ]

Item	Owner	Done
Run npm audit in backend, web and mobile and resolve high or critical findings	Operator	[ ]
Run the full test suite (npm test) on a clean install and keep the output	Operator	[ ]
Define officer and staff provisioning and deactivation procedure and tooling	Operator and municipality	[ ]
Designate the municipal data and security lead and the incident contacts	Municipality	[ ]
Decide the open business rules (suspended syndicates, insurance, cross-municipality verification)	Municipality	[ ]
Obtain legal validation of section 14 points	Counsel	[ ]
Publish a privacy notice and the retention schedule	Municipality	[ ]
Commission an independent penetration test of the deployed system	Operator and municipality	[ ]